



Integrantes:

Aguilar Carrizales Miguel Ángel - 182318

Aznar Cuevas Luis Eduardo - 179880

Beltrán Reyna David - 183636

Gómez Arreguín Donaldo Demián - 179822

Morales Hernández Roberto Emiliano - 182377

Rosales Ramírez Josué Emiliano - 181760

Materia:

CNO V: Seguridad Informática

Profesor:

López, Servando

Grupo:

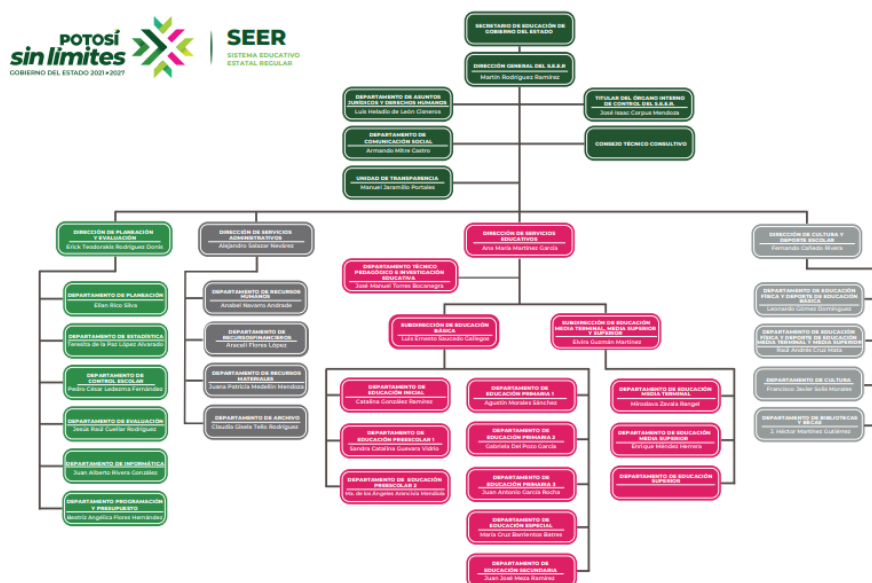
T46A

Contenido

Cláusulas de la ISO 27001:2022 en el SEER.....	2
SECCIÓN I: ALCANCE	3
1) ISO/IEC 27001:2022 (Information security, cybersecurity and privacy protection - Information security management systems - Requirements.	5
Norma base certificable. Se utiliza para establecer los requisitos formales del SGSI en el SEER, delimitar el alcance y definir el ciclo de mejora continua.	5
2) ISO/IEC 27002:2022 (Information security controls).	5
Catálogo de controles de seguridad. Se utiliza para seleccionar las buenas prácticas (controles preventivos, detectivos y correctivos) aplicables a los activos de Recursos Humanos.	5
3) ISO/IEC 27005:2018 (Information security risk management).	5
Se emplea como metodología estructurada para identificar, evaluar y tratar los riesgos (amenazas y vulnerabilidades) específicos del departamento de Recursos Humanos.	5
4) ISO/IEC 27017:2015 (Code of practice for information security controls based on ISO/IEC 27002 for cloud services).	5
Aplicada específicamente para regular el uso seguro de Microsoft Office 365 y OneDrive por parte de los administrativos.....	5
5) ISO/IEC 27018:2019 (Code of practice for protection of personally identifiable information (PII) in public clouds).	5
Esencial para garantizar que los datos personales de los docentes subidos a la nube cumplan con parámetros de privacidad.....	5
SECCIÓN III: TÉRMINOS Y DEFINICIONES.....	6
SECCIÓN IV: CONTEXTO DE LA ORGANIZACIÓN.....	7
Se ha ampliado y clasificado un inventario de 40 activos críticos relacionados con el proceso.....	7
de Recursos Humanos.	7

SECCIÓN V: LIDERAZGO	9
5.1 Políticas Generales.....	9
5.2 Políticas Funcionales.....	9
SECCIÓN VI: PLANIFICACIÓN DE RIESGOS (MATRIZ DE RIESGO)	12
6.1 Políticas internas.....	13
6.2 Políticas externas	13
SECCIÓN VII: SOPORTE.....	18
Minuta de Capacitación y Sensibilización en Seguridad de la Información (SGSI). 18	
SECCIÓN VIII: OPERACIÓN.....	21
Paso 1. Acceso únicamente con cuenta institucional	21
Procedimiento	21
Paso 2. Activación obligatoria de 2FA	22
Objetivo	22
Procedimiento operativo	22
2.1 Configuración inicial.....	23
Paso 3. Instalación de Microsoft Authenticator	23
Procedimiento	23
Paso 4. Vinculación de cuenta	24
Procedimiento	24
Paso 5. Validación del acceso.....	24
Procedimiento.....	25
SECCIÓN IX: EVALUACIÓN DEL DESEMPEÑO	26
Objetivo	26
Metodología	26
Resultados de cumplimiento	26
Hallazgos	27
Acciones Correctivas	28
Relación con políticas y riesgos	28
Resultado ejecutivo	29

Conclusión de la evaluación	29
SECCIÓN X: MEJORA.....	30
¿Qué ocurrió?.....	32
Consecuencias del incidente y medidas de contención	33
Causa raíz del incidente	34
Medidas adoptadas para eliminar la causa raíz	35
Evaluación de la eficacia de las medidas adoptadas	36
BIBLIOGRAFÍA	37



La SEER busca instaurar los valores de Integridad, Transparencia, Confidencialidad y Compromiso a la educación del estado de San Luis Potosí.

Consulta más información en nuestra página oficial: <https://seer.slp.gob.mx>

1.2 Delimitación del Alcance

▪ *Departamento Objetivo*

El Sistema de Gestión de Seguridad de la Información (SGSI) se aplica de manera específica al **Departamento de Recursos Humanos**, el cual es una unidad administrativa dependiente de la Dirección de Servicios Administrativos del Sistema Educativo Estatal Regular (SEER).

Este siendo el departamento principal administrativo de la institución, encargado de gestionar el ciclo de vida laboral de **docentes** y **trabajadores administrativos**. Siendo su labor principal:

- Administración de remuneraciones
- Control de incidencias
- Gestión de trámites de seguridad social (ISSSTE/FORTE)
- Emisión de constancias de servicio
- Operación de los procesos de selección y promoción para la educación básica.

1.3 Justificación

La implementación del **Sistema de Gestión de Seguridad de la Información (SGSI)** en el SEER tiene como objetivo establecer, implementar, mantener y mejorar continuamente un marco de seguridad que garantice la protección de los activos de información. El alcance se centra específicamente en el **Departamento de Recursos Humanos**, protegiendo la información crítica de docentes y trabajadores administrativos. La norma busca mitigar riesgos mediante la preservación de la **Confidencialidad, Integridad y Disponibilidad (Tríada CIA)** de los datos personales y laborales gestionados por esta unidad administrativa.

Este departamento, dependiente de la **Dirección de Servicios Administrativos**, es responsable de la gestión del ciclo académico de los estudiantes y del personal docente, incluyendo:

- Administración y resguardo de expedientes escolares.
- Control de inscripciones, bajas y cambios de adscripción.
- Emisión de constancias y certificados oficiales.

- Gestión de procesos de evaluación y promoción escolar.
- Coordinación de trámites ante autoridades educativas.

SECCIÓN II: REFERENCIAS NORMATIVAS

Para la correcta implementación del SGSI en el SEER, se aplican las siguientes normativas de la familia ISO/IEC 27000, utilizadas como guías rectoras y de cumplimiento obligatorio en el diseño de los controles:

1) ISO/IEC 27001:2022 (Information security, cybersecurity and privacy protection - Information security management systems - Requirements).

Norma base certificable. Se utiliza para establecer los requisitos formales del SGSI en el SEER, delimitar el alcance y definir el ciclo de mejora continua.

2) ISO/IEC 27002:2022 (Information security controls).

Catálogo de controles de seguridad. Se utiliza para seleccionar las buenas prácticas (controles preventivos, detectivos y correctivos) aplicables a los activos de Recursos Humanos.

3) ISO/IEC 27005:2018 (Information security risk management).

Se emplea como metodología estructurada para identificar, evaluar y tratar los riesgos (amenazas y vulnerabilidades) específicos del departamento de Recursos Humanos.

4) ISO/IEC 27017:2015 (Code of practice for information security controls based on ISO/IEC 27002 for cloud services).

Aplicada específicamente para regular el uso seguro de Microsoft Office 365 y OneDrive por parte de los administrativos.

5) ISO/IEC 27018:2019 (Code of practice for protection of personally identifiable information (PII) in public clouds).

Esencial para garantizar que los datos personales de los docentes subidos a la nube cumplan con parámetros de privacidad.

SECCIÓN III: TÉRMINOS Y DEFINICIONES

3.1 Definiciones clave

Para los fines de este documento y de acuerdo con la norma ISO/IEC 27001:2022, se aplican los términos definidos en la norma ISO/IEC 27000:

- **Acción preventiva** (Inglés: Preventive action). Medida de tipo pro-activo orientada a prevenir potenciales no conformidades. Es un concepto de ISO 27001:2005. En ISO 27001:2013, ya no se emplea; ha quedado englobada en Riesgos y Oportunidades.
- **Activo** (Inglés: Asset). En relación con la seguridad de la información, se refiere a cualquier información o elemento relacionado con el tratamiento de la misma (sistemas, soportes, edificios, personas...) que tenga valor para la organización.
- **Amenaza** (Inglés: Threat). Causa potencial de un incidente no deseado, que puede provocar daños a un sistema o a la organización.
- **Análisis de riesgos** (Inglés: Risk analysis). Proceso para comprender la naturaleza del riesgo y determinar el nivel de riesgo. [Fuente: Guía ISO 73: 2009] El análisis de riesgos proporciona la base para la estimación de riesgos y las decisiones sobre el tratamiento de riesgos. El análisis de riesgos incluye la estimación de riesgos.
- **Checklist**. Lista de apoyo para el auditor con los puntos a auditar, que ayuda a mantener claros los objetivos de la auditoría, sirve de evidencia del plan de auditoría, asegura su continuidad y profundidad y reduce los prejuicios del auditor y su carga de trabajo. Este tipo de listas también se pueden utilizar durante la implantación del SGSI para facilitar su desarrollo.
- **Confidencialidad** (Inglés: Confidentiality). Propiedad de la información de no ponerse a disposición o ser revelada a individuos, entidades o procesos no autorizados.
- **Control de acceso** (Inglés: Access control). Significa garantizar que el acceso a los activos esté autorizado y restringido según los requisitos comerciales y de seguridad.
- **Declaración de aplicabilidad** (Inglés: Statement of Applicability; SOA). Documento que enumera los controles aplicados por el SGSI de la organización -tras el resultado de los procesos de evaluación y tratamiento de riesgos- y su justificación, así como la justificación de las exclusiones de controles del anexo A de ISO 27001.

- **Identificación de riesgos** (Inglés: Risk identification). Proceso de encontrar, reconocer y describir riesgos [Fuente: Guía ISO 73:2009]. La identificación de riesgos implica la identificación de las fuentes del riesgo, eventos, sus causas y sus posibles consecuencias. La identificación de riesgos puede involucrar datos históricos, análisis teóricos, opiniones informadas y de expertos, y las necesidades de las partes interesadas.
- **Inventario de activos** (Inglés: Assets inventory). Lista de todos aquellos recursos (físicos, de información, software, documentos, servicios, personas, intangibles, etc.) dentro del alcance del SGSI, que tengan valor para la organización y necesiten por tanto ser protegidos de potenciales riesgos.

SECCIÓN IV: CONTEXTO DE LA ORGANIZACIÓN

Se ha ampliado y clasificado un inventario de 40 activos críticos relacionados con el proceso de Recursos Humanos.

ID / Activo	Tipo / Propietario	Tríada CIA	Justificación del Riesgo
ACT-01	Escuelas del S.E.E.R (Int)	C-Baja, I-Baja, D-Alta	Disponibilidad de servicios educativos.
ACT-02	Computadoras en salones (Int)	C-Media, I-Media, D-Alta	Punto de acceso a red y malware.
ACT-03	Servidores escuela (Int)	C-Alta, I-Alta, D-Alta	Fuga de PII (Alumnos/Maestros).
ACT-04	Impresoras Empresariales (Int)	C-Media, I-Baja, D-Media	Fuga de información impresa.
ACT-05	Gestor base de datos (Int)	C-Alta, I-Alta, D-Alta	Corrupción de registros académicos.
ACT-06	Datos alumnos/maestros (Int)	C-Alta, I-Alta, D-Media	Robo de identidad y privacidad.
ACT-07	Licencia Windows (Int)	C-Baja, I-Baja, D-Media	Vulnerabilidades sin parches.
ACT-08	Empleados administrativos (Int)	C-Alta, I-Alta, D-Media	Vector de Ingeniería Social.
ACT-09	Software computadoras clase (Int)	C-Baja, I-Media, D-Media	Inestabilidad del sistema escolar.
ACT-10	Libros Escolares (Int)	C-Baja, I-Baja, D-Baja	Pérdida de material didáctico.
ACT-11	Equipos de red (Int)	C-Baja, I-Baja, D-Alta	Caída de conectividad global.

ACT-12	Material de oficina (Int)	C-Baja, I-Media, D-Baja	Falsificación de documentos.
ACT-13	Libros/Manuales proc. (Int)	C-Media, I-Media, D-Baja	Pérdida de know-how operativo.
ACT-14	Infraestructura física (Int)	C-Baja, I-Baja, D-Alta	Acceso físico no autorizado.
ACT-15	Políticas control escolar (Int)	C-Baja, I-Alta, D-Baja	Incumplimiento normativo.
ACT-16	Software institucional (Int)	C-Alta, I-Alta, D-Alta	Compromiso de procesos críticos.
ACT-17	Protocolos de seguridad (Int)	C-Alta, I-Alta, D-Media	Incumplimiento de controles.
ACT-18	Manuales normatividad (Int)	C-Baja, I-Media, D-Baja	Falta de alineación operativa.
ACT-19	Capacitación personal (Int)	C-Baja, I-Media, D-Baja	Error humano por desconocimiento.
ACT-20	Conocimiento administrativo (Int)	C-Media, I-Baja, D-Media	Fuga de conocimiento crítico.
ACT-21	Licencia Office 365 (Ext)	C-Alta, I-Alta, D-Alta	Secuestro de sesión y PII.
ACT-22	Certificaciones (Ext)	C-Baja, I-Alta, D-Baja	Falsificación de validez oficial.
ACT-23	Plataformas Normativa Fed. (Ext)	C-Baja, I-Alta, D-Alta	Pérdida de vínculo administrativo.
ACT-24	Regulaciones Est/Fed (Ext)	C-Baja, I-Media, D-Baja	Incumplimiento legal.
ACT-25	Infraestructura ISP (Ext)	C-Baja, I-Baja, D-Alta	Interrupción del servicio escolar.
ACT-26	API Autenticación Terceros (Ext)	C-Alta, I-Alta, D-Alta	Suplantación de identidad.
ACT-27	Equipos arrendados (Ext)	C-Media, I-Media, D-Media	Fuga de datos en equipos ajenos.
ACT-28	Instalaciones externas (Ext)	C-Media, I-Baja, D-Media	Robo de equipo en eventos.
ACT-29	Centros cómputo apoyo (Ext)	C-Media, I-Media, D-Alta	Vulnerabilidad de terceros.
ACT-30	Material editoriales (Ext)	C-Baja, I-Media, D-Baja	Alteración de contenido educativo.
ACT-31	Servidores validación federal (Ext)	C-Alta, I-Alta, D-Alta	Integridad de datos oficiales.
ACT-32	Equipos de respaldo sedes (Ext)	C-Alta, I-Alta, D-Alta	Pérdida de información histórica.
ACT-33	Espacios archivo físico (Ext)	C-Alta, I-Alta, D-Baja	Acceso físico no autorizado.

ACT-34	Vehículos oficiales comp. (Ext)	C-Baja, I-Baja, D-Media	Daño o pérdida de activos.
ACT-35	Centros atención trámites (Ext)	C-Media, I-Media, D-Media	Filtración de datos de alumnos.
ACT-36	Certificaciones Fed/Est (Ext)	C-Media, I-Alta, D-Baja	Falsificación de documentos.
ACT-37	Plataformas SEP/SIGED (Ext)	C-Alta, I-Alta, D-Alta	Integridad de expediente alumno.
ACT-38	Convenios instituciones (Ext)	C-Media, I-Media, D-Media	Incumplimiento de confidencialidad.
ACT-39	Contratos proveedores SW (Ext)	C-Media, I-Media, D-Media	Riesgo de cadena de suministro.
ACT-40	Sistemas federales escolar (Ext)	C-Alta, I-Alta, D-Alta	Compromiso de base de datos SEP.

SECCIÓN V: LIDERAZGO

5.1 Políticas Generales

- **Política General Interna:** Garantizar la integridad y disponibilidad de la base de datos del personal mediante controles de acceso estrictos y respaldos periódicos.
- **Política General Externa:** Asegurar que los proveedores de servicios en la nube (Office 365) y plataformas federales cumplan con estándares de protección de datos personales.
-

5.2 Políticas Funcionales

5.2.1 Internas:

<i>Política</i>	Política Funcional	Estándar / Directriz	Procedimiento / Línea Base
1	Control de Acceso a Bases de Datos (Activo 5)	Uso obligatorio de contraseñas de alta complejidad (12+ caracteres).	Procedimiento de cambio de contraseña cada 90 días naturales.

2	Seguridad en Equipos de Cómputo (Activo 2)	Prohibición de instalación de software no autorizado por el Depto. de Informática.	Bloqueo de puertos USB y privilegios de administrador para usuarios finales.
3	Gestión de Respaldos (Activo 3)	Garantizar la disponibilidad de datos de alumnos y maestros ante fallos críticos.	Ejecución automática de backups diarios a las 23:00 hrs en servidores locales.
4	Seguridad Física de Oficinas (Activo 14)	Política de "Escritorio Limpio" al finalizar la jornada laboral.	Línea Base: Resguardo de sellos y papelería oficial en archiveros con llave.
5	Uso de Redes Institucionales (Activo 11)	Restricción de acceso a sitios web de alto riesgo o no relacionados con la labor educativa.	Monitorización periódica de logs de tráfico por el personal técnico.
6	Integridad de Expedientes Físicos (Activo 13)	Solo personal autorizado de RRHH puede consultar expedientes de docentes.	Bitácora obligatoria de entrada/salida de documentos del archivo físico.
7	Seguridad en la Contratación (Activo 8)	Validación de antecedentes académicos y profesionales de nuevos ingresos.	Entrevistas técnicas y cotejo de títulos profesionales ante instancias oficiales.
8	Mantenimiento de Infraestructura (Activo 14)	Reporte preventivo de fallas en instalaciones eléctricas o de red.	Programa de mantenimiento trimestral para racks y servidores internos.
9	Actualización de Software (Activo 16)	Todos los sistemas institucionales deben operar con parches de seguridad vigentes.	Aplicación mensual de actualizaciones críticas de seguridad en Windows.

10	Capacitación en Seguridad (Activo 19)	El personal debe asistir a una sesión de concientización sobre riesgos digitales cada año.	Línea Base: 100% de asistencia del personal administrativo a talleres de phishing.
-----------	---------------------------------------	--	--

5.2.1 Externas:

<i>Política</i>	Política Funcional	Estándar / Directriz	Procedimiento / Línea Base
1	Uso de Servicios en la Nube (Activo 1)	Uso estricto de la cuenta institucional de Office 365 para comunicaciones oficiales.	Habilitación obligatoria de Autenticación de Dos Factores (2FA).
2	Cumplimiento Normativo (Activo 17)	Alineación total con las directrices de la SEP y el SIGED.	Revisión trimestral de actualizaciones en la normativa federal de seguridad.
3	Gestión de Proveedores de Internet (Activo 5)	Asegurar una disponibilidad del servicio de internet del 99.9% (SLA).	Procedimiento de reporte inmediato ante caída del enlace principal con el ISP.
4	Intercambio Seguro de Datos (Activo 11)	Validación de certificados SSL/TLS en servidores federales de validación de datos.	Bloqueo de conexiones a portales externos sin cifrado HTTPS.

5	Seguridad en Equipos Arrendados (Activo 7)	Los equipos externos deben cumplir con los mismos estándares que los internos.	Borrado seguro de datos antes de la devolución de equipos a proveedores.
6	Acceso de Terceros (Activo 19)	Los contratos con proveedores deben incluir cláusulas de confidencialidad de datos (NDA).	Revisión legal de contratos antes de otorgar accesos remotos a sistemas.
7	Respaldo en Sedes Alternas (Activo 12)	Almacenamiento de copias de seguridad fuera de las instalaciones principales.	Transferencia semanal de archivos cifrados a centros de respaldo estatales.
8	Autenticación vía APIs (Activo 6)	Monitoreo de seguridad en el consumo de APIs de autenticación de terceros.	Auditoría semestral de tokens de acceso y llaves de API activas.
9	Gestión de Eventos Externos (Activo 8)	Protección de activos móviles durante eventos académicos fuera del SEER.	Uso obligatorio de VPN corporativa para conexiones en redes Wi-Fi públicas.
10	Validación de Material Externo (Activo 10)	Análisis antivirus de todo material digital proporcionado por editoriales externas.	Procedimiento de escaneo en equipos aislados (Sandboxing) antes de su red.

SECCIÓN VI: PLANIFICACIÓN DE RIESGOS (MATRIZ DE RIESGO)

6.1 Políticas internas

Ubicación de políticas internas de acuerdo con su riesgo.

Políticas internas con su ID:

1. P-I1 -> Acceso no autorizado a BD de nómina
2. P-I2 -> Infección por Malware en PCs de clase
3. P-I3 -> Pérdida de datos por falla de servidor
4. P-I4 -> Robo de sellos o papelería oficial
5. P-I5 -> Exfiltración de datos vía redes sociales
6. P-I6 -> Alteración de expedientes físicos
7. P-I7 -> Contratación de personal no calificado
8. P-I8 -> Incendio/Falla eléctrica en el Rack
9. P-I9 -> Explotación de vulnerabilidades (SUID)
10. P-I10 -> Error humano por falta de capacitación

01 – INSIGNIFICANTE.	02 – MENOR.	03 – SIGNIFICATIVO.	04 – MAYOR.	05 – SEVERO.	
		P-I2	P-I10		
	P-I4		P-I5		
			P-I6	P-I1 / P-I3 / P-I9	
				P-I7 / P-I8	



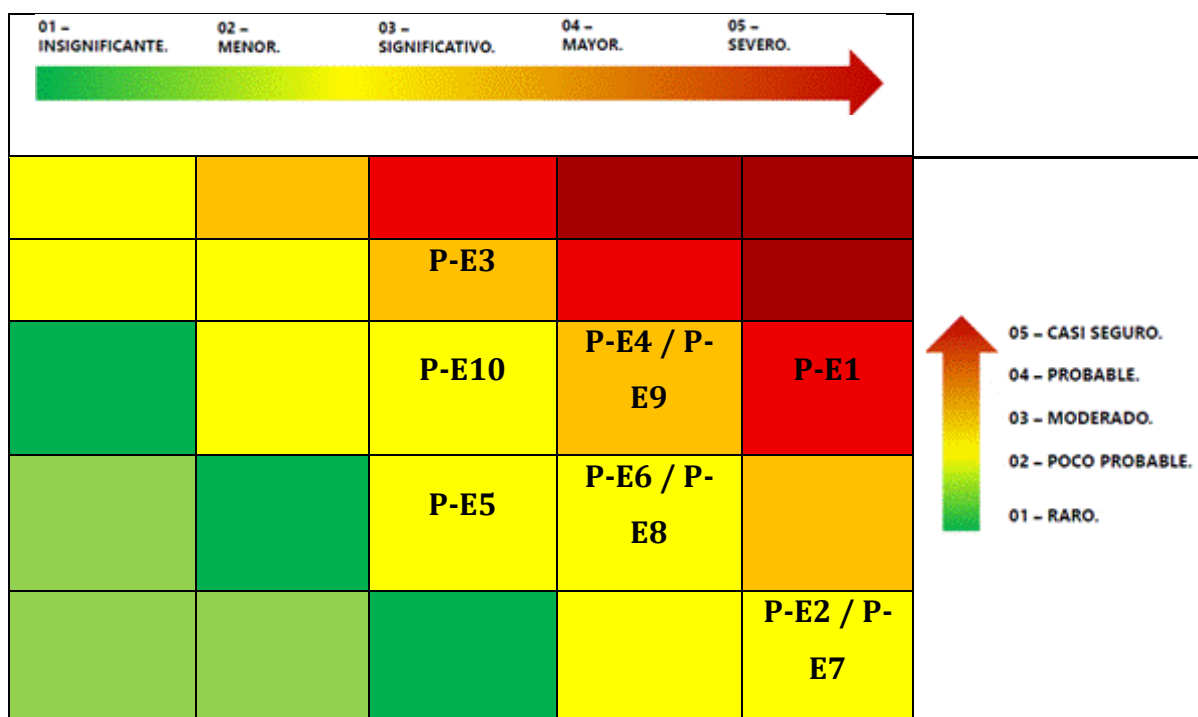
05 – CASI SEGURO.
 04 – PROBABLE.
 03 – MODERADO.
 02 – POCO PROBABLE.
 01 – RARO.

6.2 Políticas externas

Ubicación de políticas externas de acuerdo con su riesgo.

Políticas externas con su ID:

1. P-E1 -> Secuestro de sesión en Office 365
2. P-E2 -> Sanciones por incumplimiento (SEP)
3. P-E3 -> Interrupción del servicio de Internet
4. P-E4 -> Intercepción de datos en tránsito
5. P-E5 -> Falla de hardware en equipos rentados
6. P-E6 -> Acceso malintencionado de terceros
7. P-E7 -> Desastre natural en sede de respaldo
8. P-E8 -> Compromiso de claves de API externas
9. P-E9 -> Ataque Tabnabbing en eventos externos
10. P-E10 -> Malware en archivos de editoriales



Activo	Medida	Clasificación	Justificación
1. Uso de Servicios en la Nube	Cuenta institucional 0365 + 2FA obligatoria	Mitigar	Reduce la probabilidad de accesos no autorizados, pero no elimina el riesgo de la nube.
17. Cumplimiento Normativo	Alineación con SEP/SIGED + revisiones trimestrales	Aceptar	El riesgo normativo no se elimina ni transfiere; se acepta y se monitorea activamente.
5. Gestión de Proveedores de Internet	SLA 99.9% + reporte inmediato de caída	Transferir	La disponibilidad se transfiere parcialmente al ISP mediante SLA; el reporte mitiga el impacto.
11. Intercambio Seguro de Datos	Validación SSL/TLS + bloqueo de HTTP	Mitigar	Reduce el riesgo de interceptación o manipulación de datos en tránsito.
7. Equipos Arrendados	Mismos estándares + borrado seguro	Mitigar	Disminuye el riesgo de fuga de datos por equipos externos, pero no lo elimina.
19. Acceso de Terceros	Cláusulas NDA + revisión legal de contratos	Transferir	El riesgo de incumplimiento de confidencialidad se transfiere legalmente al proveedor.

12. Respaldo en Sedes Alternas	Copias fuera de instalaciones + transferencia cifrada semanal	Mitigar	Reduce el riesgo de pérdida de datos ante desastre local.
6. Autenticación vía APIs	Monitoreo de seguridad + auditoría semestral de tokens	Mitigar	Control continuo sobre riesgos de autenticación delegada.
8. Gestión de Eventos Externos	VPN obligatoria en Wi-Fi pública para activos móviles	Mitigar	Reduce exposición en redes no confiables; no elimina todos los riesgos.
10. Validación de Material Externo	Antivirus + sandboxing antes de usar	Mitigar (casi eliminar)	Si se hace sandboxing riguroso, se elimina el riesgo de ejecución directa. Pero como hay análisis previo, se clasifica como mitigación fuerte.

Activo	Medida descrita	Clasificación	Justificación
1. Uso de Servicios en la Nube	Cuenta institucional 0365 + 2FA obligatoria	Mitigar	Reduce la probabilidad de accesos no autorizados, pero no elimina el riesgo de la nube.
17. Cumplimiento Normativo	Alineación con SEP/SIGED + revisiones trimestrales	Aceptar	El riesgo normativo no se elimina ni transfiere; se acepta y

			se monitorea activamente.
5. Gestión de Proveedores de Internet	SLA 99.9% + reporte inmediato de caída	Transferir	La disponibilidad se transfiere parcialmente al ISP mediante SLA; el reporte mitiga el impacto.
11. Intercambio Seguro de Datos	Validación SSL/TLS + bloqueo de HTTP	Mitigar	Reduce el riesgo de interceptación o manipulación de datos en tránsito.
7. Equipos Arrendados	Mismos estándares + borrado seguro	Mitigar	Disminuye el riesgo de fuga de datos por equipos externos, pero no lo elimina.
19. Acceso de Terceros	Cláusulas NDA + revisión legal de contratos	Transferir	El riesgo de incumplimiento de confidencialidad se transfiere legalmente al proveedor.
12. Respaldo en Sedes Alternas	Copias fuera de instalaciones + transferencia cifrada semanal	Mitigar	Reduce el riesgo de pérdida de datos ante desastre local.
6. Autenticación vía APIs	Monitoreo de seguridad + auditoría semestral de tokens	Mitigar	Control continuo sobre riesgos de autenticación delegada.
8. Gestión de Eventos Externos	VPN obligatoria en Wi-Fi pública para activos móviles	Mitigar	Reduce exposición en redes no confiables;

			no elimina todos los riesgos.
10. Validación de Material Externo	Antivirus + sandboxing antes de usar	Mitigar (casi eliminar)	Si se hace sandboxing riguroso, se elimina el riesgo de ejecución directa. Pero como hay análisis previo, se clasifica como mitigación fuerte.

SECCIÓN VII: SOPORTE

Minuta de Capacitación y Sensibilización en Seguridad de la Información (SGSI)

CÓDIGO DE DOCUMENTO: SEER-SGSI-MIN-2026-001

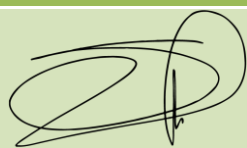
PROYECTO: Implementación de ISO/IEC 27001:2022 en el Departamento de Recursos Humanos.

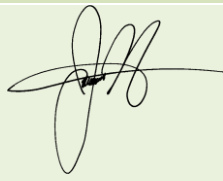
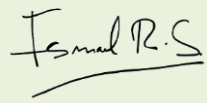
FECHA: 11 de mayo de 2026.

HORA: 09:00 AM - 12:30 PM.

UBICACIÓN: Sala de Juntas "B", Edificio Central SEER, San Luis Potosí.

1. ASISTENTES Y ROLES

Nombre	Cargo / Departamento	Firma de Asistencia
Anabel Navarro Andrade	Titular del Depto. de Recursos Humanos	

Juan Alberto Rivera González	Jefe del Depto. de Informática	
Equipo Técnico T46A	Consultores de Seguridad (Integrantes 182318, 179880, 183636, 179822, 182377, 181760)	
Personal Administrativo	Usuarios finales del Departamento de RRHH	
Maria Rosales	Usuario	
Carlos Gomez	Usuario	
Pedro Jimenez	Usuario	

2. OBJETIVOS DE LA SESIÓN

- A. **Competencia y Concientización:** Asegurar que el personal administrativo comprenda su rol dentro del SGSI y las consecuencias del incumplimiento de las políticas.

- B. **Mitigación de Riesgos Críticos:** Instruir sobre los vectores de ataque identificados en la matriz de riesgo, específicamente Phishing y Reverse Tabnabbing.
- C. **Gestión de Activos:** Reforzar el uso correcto de las licencias de Office 365 y el manejo de datos de maestros y alumnos.

3. ORDEN DEL DÍA Y PROCESOS DETALLADOS

- A. **Introducción al Marco Normativo (45 min)**
 - Explicación de la importancia de la Tríada CIA (Confidencialidad, Integridad y Disponibilidad) en la gestión de remuneraciones y trámites de seguridad social (ISSSTE).
 - Presentación del Alcance del SGSI limitado al Departamento de Recursos Humanos.
- B. **Taller Práctico de Ingeniería Social (60 min)**
 - **Simulacro de Phishing:** Análisis de correos fraudulentos que suplantan a la Secretaría o proveedores externos.
 - **Demostración de Reverse Tabnabbing:** Explicación técnica de cómo un enlace malicioso puede comprometer las credenciales del personal al no utilizar el atributo rel="noopener".
 - **Procedimiento de Respuesta:** Definición del canal oficial para reportar correos o comportamientos anómalos en el equipo de cómputo.
- C. **Control de Acceso y Gestión de Identidad (45 min)**
 - Instalación y configuración de la Autenticación de Dos Factores (2FA) en las cuentas de Office 365.
 - Instrucciones para el uso del Gestor de Base de Datos y la prohibición de compartir credenciales entre administrativos.
- D. **Seguridad Física y Documental (30 min)**
 - Implementación de la política de **Escritorio Limpio:** Procedimiento de resguardo de expedientes físicos, sellos y manuales al finalizar la jornada laboral.
 - Manejo seguro de material impreso y papelería oficial para evitar la duplicación no autorizada.

4. ACUERDOS Y COMPROMISOS

- **AC01:** El Departamento de Informática realizará un escaneo de vulnerabilidades quincenal sobre los activos internos de RRHH.
- **AC02:** El personal administrativo firma un Acuerdo de Confidencialidad (NDA) vinculado a su contrato laboral.
- **AC03:** Se establece un periodo de gracia de 5 días hábiles para que todos los usuarios actualicen sus contraseñas bajo el nuevo estándar de complejidad (12+ caracteres).

5. CIERRE Y VALIDACIÓN

Siendo las 12:30 PM del día 11 de mayo de 2026, se da por terminada la sesión de capacitación, validando que el personal administrativo ha adquirido las competencias necesarias para operar bajo el marco de la ISO/IEC 27001:2022 en el SEER.

SECCIÓN VIII: OPERACIÓN

Operación del tratamiento de riesgos para una sola de las políticas, el paso a paso del procedimiento / línea base de la política seleccionada (revisar sección 5).

Implementación de dos factores

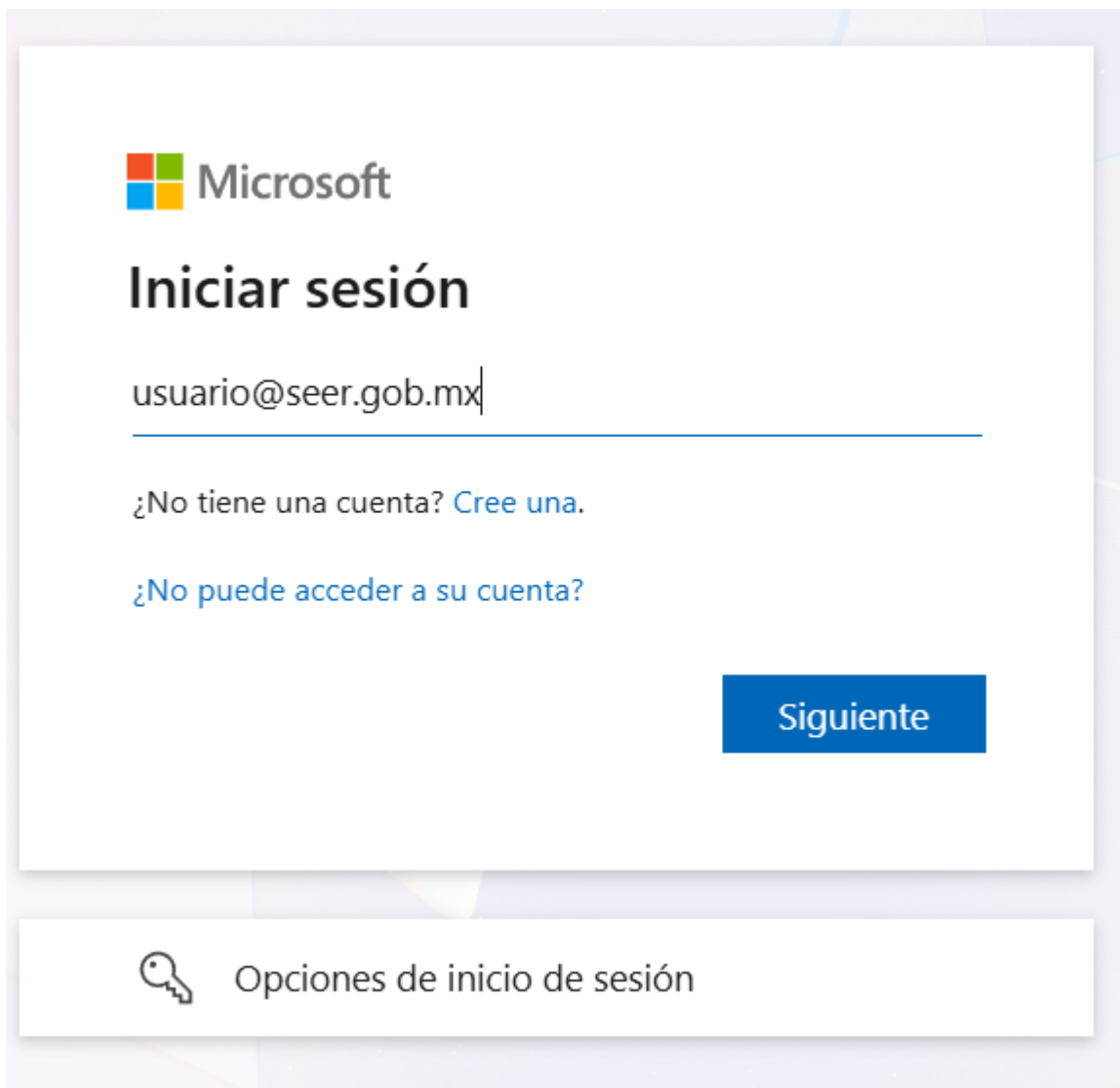
<i>Uso de Servicios en la Nube (Activo 1)</i>	Uso estricto de la cuenta institucional de Office 365 para comunicaciones oficiales.	Habilitación obligatoria de Autenticación de Dos Factores (2FA).
--	---	---

Se realizará la operación para la siguiente política

Paso 1. Acceso únicamente con cuenta institucional

Procedimiento

1. Abrir navegador web.
2. Ingresar a:
<https://portal.office.com>
3. Escribir el correo institucional del SEER.



 Microsoft

Iniciar sesión

usuario@seer.gob.mx

¿No tiene una cuenta? [Cree una.](#)

¿No puede acceder a su cuenta?

[Siguiendo](#)

 Opciones de inicio de sesión

4. Ingresar contraseña.

Paso 2. Activación obligatoria de 2FA

Objetivo

Agregar una segunda capa de seguridad para evitar accesos no autorizados.

Procedimiento operativo

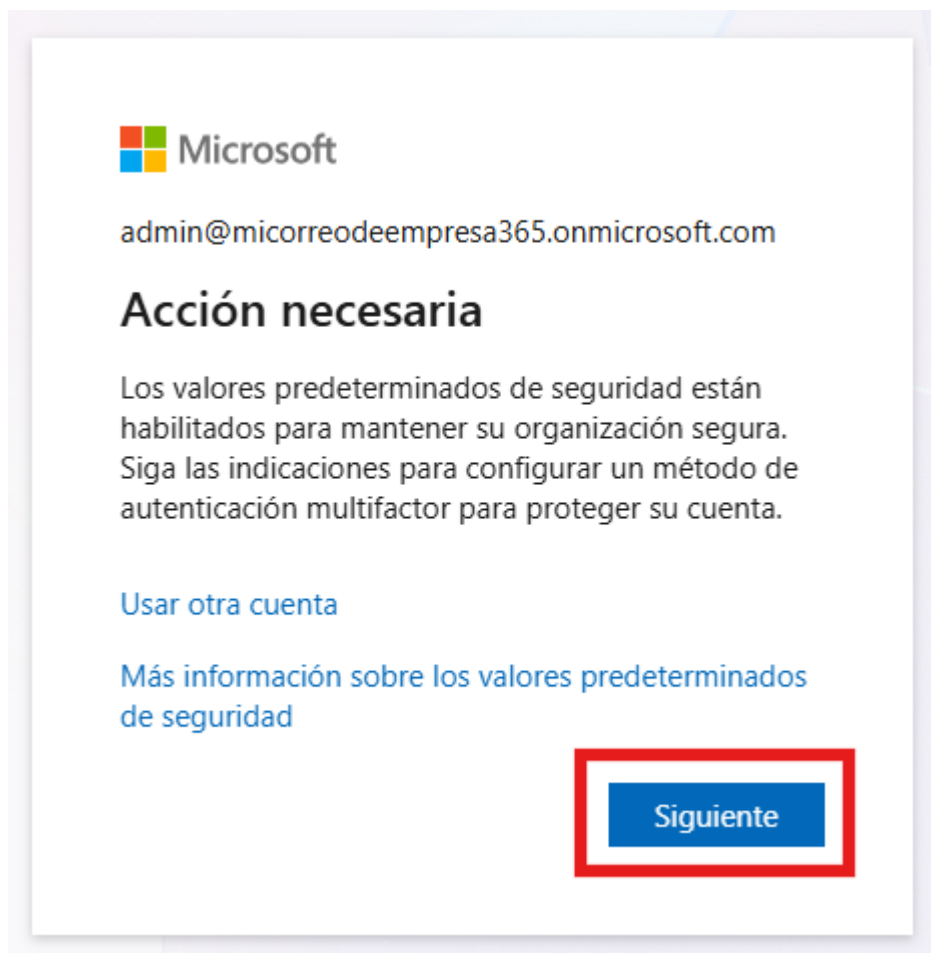
2.1 Configuración inicial

1. Después del primer inicio de sesión, Office 365 solicitará:

Más información requerida

2. Seleccionar:

Configurar ahora



Paso 3. Instalación de Microsoft Authenticator

Procedimiento

1. Abrir Play Store o App Store.
2. Buscar:
Microsoft Authenticator
3. Instalar la aplicación oficial de Microsoft.

13:07



< Search



Microsoft Authenticator

Microsoft Corporation

GET



190K RATINGS

4.8



AGE

4+

Years Old

CHART

#4

Productivity

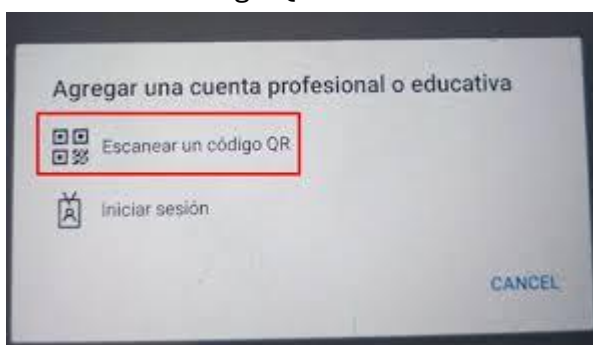
DEV

Microso

Paso 4. Vinculación de cuenta

Procedimiento

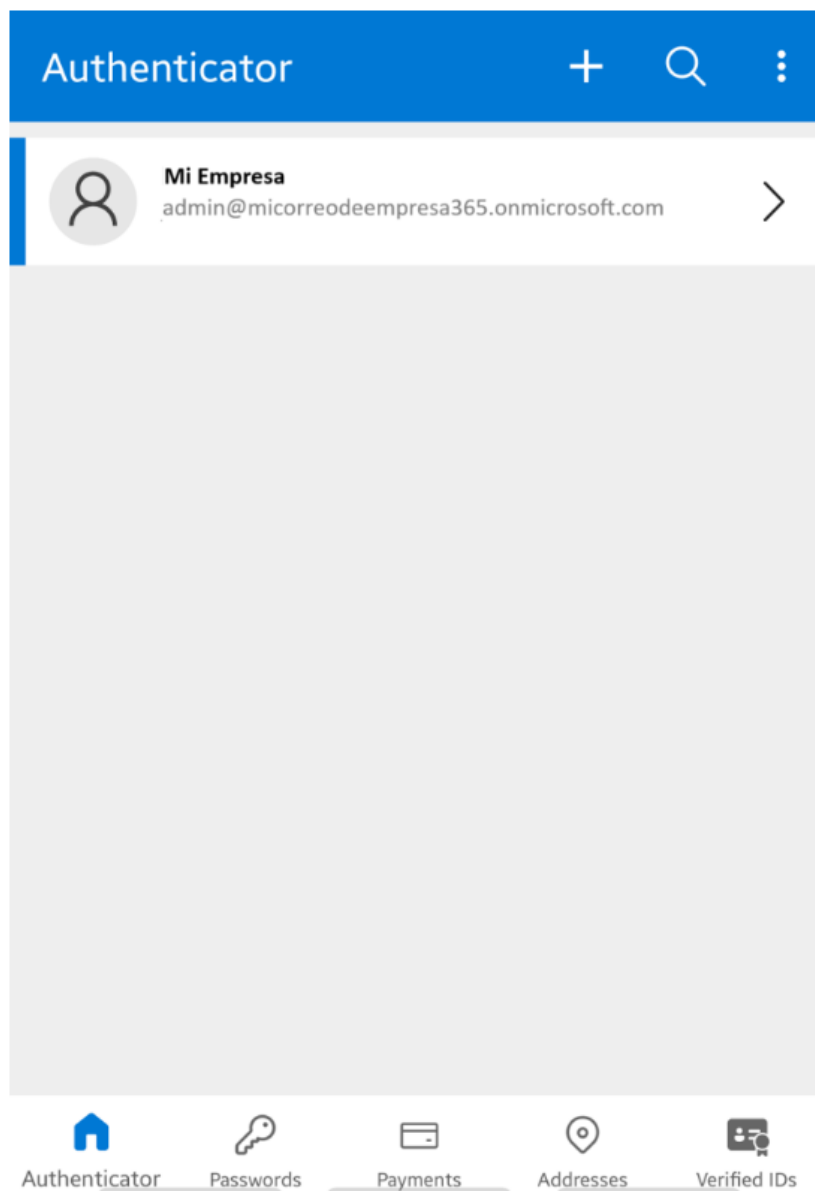
1. En la pantalla de Office 365 aparecerá un código QR.
2. Abrir Microsoft Authenticator.
3. Seleccionar:
Agregar cuenta
4. Escanear el código QR.



Paso 5. Validación del acceso

Procedimiento

1. El sistema enviará una notificación al celular.
2. El usuario debe aprobar el acceso.
3. Office 365 mostrará el siguiente mensaje:



Ahora sólo queda volver a iniciar sesión.

Con esta política:

- Se protege el acceso a Office 365.
- Se reduce el riesgo de secuestro de sesión.
- Se evita el uso de cuentas personales.
- Se mejora la trazabilidad institucional.

SECCIÓN IX: EVALUACIÓN DEL DESEMPEÑO

Objetivo

Evaluar la eficacia y el nivel de cumplimiento del **Sistema de Gestión de Seguridad de la Información (SGSI)** en el Departamento de Recursos Humanos del SEER, verificando la aplicación de controles, políticas y procedimientos que garanticen la protección de la información sensible del personal docente y administrativo.

Metodología

La evaluación se realizó mediante:

- **Checklist de controles** (18 ítems verificados).
- **Entrevistas** con personal de TI y Recursos Humanos.
- **Revisión documental** de políticas, bitácoras, contratos y registros.
- **Evidencia física y digital** (logs de acceso, respaldos, minutas de capacitación).

Resultados de cumplimiento

ID	Control a Evaluar	Evidencia	Cumple
C-01	Existe un alcance formal del SGSI documentado	Documento de alcance aprobado	Sí
C-02	Se cuenta con políticas de seguridad aprobadas	Manual de políticas	Sí
C-03	Existe inventario actualizado de activos	Inventario TI y físico	Sí
C-04	Las contraseñas cumplen con complejidad mínima	Política de contraseñas	Sí
C-05	Está habilitado el doble factor de autenticación (2FA)	Configuración en Office 365	Parcial
C-06	Solo se utilizan cuentas institucionales	Validación de accesos	Sí

C-07	Se aplican actualizaciones de seguridad periódicas	Bitácora de actualizaciones	Sí
C-08	Los equipos cuentan con antivirus actualizado	Consola antivirus	Sí
C-09	Se realizan respaldos automáticos de información	Logs de backup	Parcial
C-10	Existe protección física de expedientes y documentos	Archiveros bajo llave	Sí
C-11	El acceso a expedientes está restringido	Bitácora de acceso	Sí
C-12	El personal recibió capacitación en seguridad	Minutas/listas de asistencia	Parcial
C-13	Existe procedimiento para reportar incidentes	Documento de gestión de incidentes	No
C-14	Los proveedores firman acuerdos de confidencialidad	Contratos/NDA	Sí
C-15	Existe una matriz de riesgos actualizada	Matriz de riesgos	Sí
C-16	Se cuenta con plan de continuidad de negocio	Documento BCP	No
C-17	Se monitorean accesos y actividad en red	Logs y monitoreo	Sí
C-18	La dirección revisa periódicamente el SGSI	Minutas de revisión	Sí

Hallazgos

Tipo	Descripción	Impacto
No conformidad	Falta de plan de continuidad de negocio	Riesgo de indisponibilidad de servicios críticos
No conformidad	Procedimiento de gestión de incidentes incompleto	Riesgo de respuesta tardía ante incidentes
Observación	Capacitación anual no cubrió a todo el personal	Riesgo de desconocimiento de políticas
Oportunidad de mejora	Automatizar respaldos en nube institucional	Mayor disponibilidad y seguridad de datos
Oportunidad de mejora	Ampliar cobertura de 2FA a sistemas internos	Reducción de riesgo de accesos no autorizados

Acciones Correctivas

Hallazgos	Responsable	Prioridad	Fecha Compromiso
Plan de continuidad de negocio	Dirección de TI	Alta	30 días
Procedimiento de gestión de incidentes	Comité de Seguridad	Media	45 días
Capacitación completa	Dirección de RH	Media	60 días
Automatización de respaldos	Área de TI	Alta	30 días
Ampliación de 2FA	Área de TI	Alta	45 días

Relación con políticas y riesgos

- Políticas de seguridad institucional: contraseñas, accesos, confidencialidad.
- Matriz de riesgos: pérdida de información, indisponibilidad de servicios, accesos no autorizados.
- Controles definidos previamente: administrativos, técnicos y físicos.

Resultado ejecutivo

Aspecto	Resultado
Controles evaluados	18
Cumplimiento total	12 (67%)
Cumplimiento parcial	4 (22%)
No conformidades	2 (11%)
Nivel de madurez	Intermedio
Estado general	Cumplimiento del 75% de los controles
Recomendaciones	Fortalecer continuidad de negocio, ampliar 2FA, asegurar capacitación total del personal

Conclusión de la evaluación

El SGSI en Recursos Humanos presenta un nivel de madurez intermedio, con un cumplimiento del 75% de los controles evaluados. Se recomienda fortalecer la continuidad de negocio, ampliar la cobertura de doble factor de autenticación y asegurar la capacitación total del personal para alcanzar un estado de cumplimiento robusto y alineado con los estándares de seguridad de la información.

SECCIÓN X: MEJORA



COMUNICADO DE SEGURIDAD INFORMÁTICA

Incidente de acceso no autorizado en Office 365

El 18 de mayo de 2026, un usuario de Recursos Humanos recibió un correo de phishing que simulaba ser soporte de Office 365, solicitando "verificar urgentemente la cuenta institucional". El enlace dirigía a una página falsificada similar al portal Microsoft.

¿Qué ocurrió?

El usuario ingresó sus credenciales y aprobó la notificación 2FA, permitiendo al atacante acceder a: correos internos, OneDrive, información administrativa de docentes y comunicaciones de RRHH. El incidente fue detectado horas después por actividades sospechosas en los logs de acceso.

Consecuencias Identificadas



Exposición de Información

Riesgo de exposición de información confidencial y posible filtración de documentos administrativos sensibles del personal.



Accesos No Autorizados

Accesos detectados desde IPs externas, compromiso temporal de cuenta institucional y riesgo de propagación mediante correos internos.



Causa Raíz

Falta de concientización ante ingeniería social: personal sin capacitación, ausencia de simulacros, dependencia excesiva en 2FA.

El 2FA solo no es suficiente sin capacitación continua y monitoreo activo.

Medidas de Contención

Contención Inmediata

Bloqueo temporal de cuenta comprometida
Revocación de sesiones activas
Restablecimiento obligatorio de contraseña
Escaneo antivirus del equipo

Mitigación

Notificación al personal administrativo
Monitoreo reforzado de Office 365
Políticas de acceso condicional
Alertas en Microsoft Defender

Medidas Adoptadas

Técnicas: Acceso condicional en M365, Safe Links y Safe Attachments, monitoreo con SIEM
Administrativas: Programa trimestral de concientización, simulacros de phishing

Resultados (30 días)

100% usuarios capacitados
87% detección correcta en simulacros
75% reducción de clics sospechosos
0 incidentes posteriores



¿Qué ocurrió?

El día 18 de mayo de 2026, un usuario administrativo del Departamento de Recursos Humanos del SEER recibió un correo electrónico aparentemente enviado por el área de soporte institucional de Office 365.

El mensaje indicaba que era necesario “*verificar urgentemente la cuenta institucional*” debido a una supuesta anomalía en el buzón corporativo. El correo contenía un enlace que redirigía a una página web falsificada con apariencia similar al portal oficial de Microsoft.

El empleado ingresó sus credenciales institucionales dentro del sitio fraudulento y posteriormente **aprobó** una notificación de autenticación multifactor (2FA) enviada a su dispositivo móvil, creyendo que correspondía al proceso legítimo.

A través de este mecanismo, el atacante obtuvo acceso temporal a la cuenta institucional del usuario y logró acceder a:

- Correos electrónicos internos.
- Documentos almacenados en OneDrive.
- Información administrativa relacionada con docentes.
- Comunicaciones internas del área de Recursos Humanos.

El incidente fue detectado horas después debido a actividades sospechosas registradas en los logs de inicio de sesión de Microsoft 365.

Consecuencias del incidente y medidas de contención

Consecuencias identificadas

El incidente generó diversas consecuencias de seguridad:

- Riesgo de exposición de información confidencial.
- Posible filtración de documentos administrativos.
- Accesos no autorizados desde direcciones IP externas.
- Compromiso temporal de la cuenta institucional.
- Riesgo de propagación del ataque mediante correos internos.

Aunque no se detectó alteración de información crítica ni pérdida permanente de datos, el incidente representó una afectación importante a la confidencialidad de la información institucional.

Medidas de contención implementadas

Al detectarse el incidente, el Departamento de Informática ejecutó las siguientes acciones:

- Contención inmediata
 - o Bloqueo temporal de la cuenta comprometida.
 - o Revocación de sesiones activas en Microsoft 365.
 - o Restablecimiento obligatorio de contraseña.
 - o Revocación de tokens de autenticación.
 - o Escaneo antivirus y antimalware del equipo afectado.
 - o Revisión de logs de acceso y actividad sospechosa.
- Medidas de mitigación
 - o Notificación inmediata al personal administrativo.
 - o Monitoreo reforzado de accesos a Office 365.
 - o Aplicación de políticas de acceso condicional.
 - o Restricción de accesos desde ubicaciones no autorizadas.
 - o Incremento de alertas de seguridad en Microsoft Defender.

Causa raíz del incidente

Después del análisis realizado por el área de informática y los responsables del SGSI, se determinó que la causa raíz principal fue: ***Falta de concientización del usuario ante ataques de ingeniería social.***

Aunque existía una política de uso obligatorio de 2FA, el personal no contaba con suficiente capacitación para identificar:

- Correos de phishing.
- URLs fraudulentas.
- Solicitudes falsas de autenticación.
- Técnicas de MFA Fatigue o MFA Prompt Bombing.

Asimismo, se detectaron debilidades adicionales:

- Ausencia de simulacros periódicos de phishing.
- Falta de campañas continuas de sensibilización.
- Dependencia excesiva en el 2FA como único mecanismo de protección.
- Carencia de políticas de Zero Trust y acceso contextual.

Medidas adoptadas para eliminar la causa raíz

Con el objetivo de evitar la repetición del incidente, el SEER implementó un plan de mejora continua alineado con la cláusula 10 de la ISO/IEC 27001:2022.

Medidas técnicas

1. Implementación de acceso condicional

Se configuraron políticas de Conditional Access en Microsoft 365 para:

- Bloquear accesos desde países no autorizados.
- Restringir inicios de sesión sospechosos.
- Solicitar validación adicional ante comportamientos anómalos.

2. Protección avanzada contra phishing

Se habilitaron:

- Safe Links.
- Safe Attachments.
- Filtros anti-phishing avanzados.
- Detección automática de URLs maliciosas.

3. Fortalecimiento del monitoreo

Se integró monitoreo centralizado mediante:

- Logs de autenticación.
- Alertas SIEM.
- Detección de comportamiento anómalo.
- Auditoría continua de accesos.

Medidas administrativas

1. Programa de concientización permanente

Se estableció un programa trimestral obligatorio sobre:

- Ingeniería social.
- Phishing.
- Protección de credenciales.
- Uso seguro de Office 365.

- Gestión de incidentes.

2. Simulacros controlados de phishing

El área de informática realizará campañas internas periódicas para medir:

- Nivel de detección.
- Tasa de clics.
- Reportes de correos sospechosos.
- Nivel de madurez del personal.

3. Actualización de políticas del SGSI

Se actualizó la política funcional externa “Uso de Servicios en la Nube”, incorporando:

- Validación obligatoria de enlaces.
- Restricción de aprobaciones MFA sospechosas.
- Procedimiento formal de reporte de phishing.
- Reglas de acceso remoto seguro.

Evaluación de la eficacia de las medidas adoptadas

Después de implementar las acciones correctivas y preventivas, se realizó una evaluación interna durante un periodo de 30 días.

Resultados obtenidos

Indicador	Resultado
Usuarios capacitados	100%
Simulacros de phishing detectados correctamente	87%
Reducción de clics en enlaces sospechosos	75%
Intentos de acceso sospechoso bloqueados	100%
Incidentes posteriores registrados	0

Evaluación general

Las medidas implementadas fueron consideradas eficaces debido a que:

- Se fortaleció la cultura de seguridad.
- Disminuyó significativamente la probabilidad de compromiso.
- Mejoró la detección temprana de ataques.
- Se reforzó la protección de Office 365.
- Se incrementó la madurez del SGSI.

Asimismo, se concluyó que el uso de 2FA por sí solo no es suficiente si no se acompaña de capacitación continua y monitoreo activo.

BIBLIOGRAFÍA

- International Organization for Standardization (ISO). (2022). ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.
- International Organization for Standardization (ISO). (2022). ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls. ISO.
- International Organization for Standardization (ISO). (2018). ISO 31000:2018 Risk management — Guidelines. ISO.
- Microsoft Learn. (s. f.). Microsoft 365 security documentation. Microsoft.
<https://learn.microsoft.com/en-us/microsoft-365/security/>
- Microsoft Learn - Microsoft Authenticator. (s. f.). Microsoft Authenticator app. Microsoft.
- Sistema Educativo Estatal Regular (SEER). (s. f.). Portal oficial del Sistema Educativo Estatal Regular. Gobierno del Estado de San Luis Potosí.
- Instituto Nacional de Ciberseguridad (INCIBE). (s. f.). Guías de ciberseguridad y continuidad de negocio. INCIBE.
- National Institute of Standards and Technology (NIST). (2020). Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5). U.S. Department of Commerce. <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
- National Institute of Standards and Technology (NIST). (2020). Zero Trust Architecture (SP 800-207). U.S. Department of Commerce.
<https://csrc.nist.gov/publications/detail/sp/800-207/final>
- FIRST.org. (2019). Common Vulnerability Scoring System Version 3.1: Specification Document. FIRST. <https://www.first.org/cvss/v3-1/specification-document>
- Nominalia. (s. f.). Office 365: activar, configurar y acceder con autenticación de dos factores. <https://www.nominalia.com/help/office-365-activar-configurar-y-acceder-con-2fa-autenticacion-de-2-factores/>

- Microsoft. (s. f.). Microsoft 365. Microsoft 365 Official Site
- Whitman, M. E., & Mattord, H. J. (2022). Principles of Information Security (7th ed.). Cengage Learning.
- Stallings, W., & Brown, L. (2018). Computer Security: Principles and Practice (4th ed.). Pearson.
- Calder, A. (2023). ISO 27001/ISO 27002: A Pocket Guide (10th ed.). IT Governance Publishing.
- Humphreys, E. (2021). Implementing the ISO/IEC 27001 Information Security Management System Standard (3rd ed.). Artech House.

EQUIPO 1

- AGUILAR CARRIZALES MIGUEL ANGEL - 182318
- AZNAR CUEVAS LUIS EDUARDO - 179880
- BELTRÁN REYNA DAVID - 183636
- GOMEZ ARREGUÍN DONALDO DEMIÁN - 179822
- MORALES HERNANDEZ ROBERTO EMILIANO - 182377
- ROSALES RAMIREZ JOSUE EMILIANO - 181760

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ
SECRETARÍA EDUCATIVO ESTATAL REGULAR



Sistema de Gestión de Seguridad de la Información

I M P L E M E N T A N D O S G S I

¿QUÉ ES ISO/IEC 27001:2022?



La ISO/IEC 27001:2022 es una norma internacional enfocada en la implementación de Sistemas de Gestión de Seguridad de la Información (SGSI).

Su objetivo principal es proteger la información mediante controles de seguridad orientados a:

- **Confidencialidad**
- **Integridad**
- **Disponibilidad**

¿Por qué es importante?

Es importante porque permite a las organizaciones reducir riesgos de ciberseguridad, proteger datos sensibles, establecer políticas de seguridad, gestionar incidentes, mejorar la continuidad operativa y cumplir requisitos normativos.

APLICACIÓN EN EL SEER

El SGSI se implementa específicamente en el ***Departamento de Recursos Humanos*** debido a que administra:

- Datos de docentes.
- Información laboral.
- Expedientes.
- Remuneraciones.
- Accesos institucionales.



PROBLEMÁTICA IDENTIFICADA

Política Funcional Externa 1: Uso de Servicios en la Nube (Office 365)

El SEER utiliza servicios en la nube para:

- Correos institucionales.
- Compartición de archivos.
- Comunicación administrativa.
- Gestión documental.

Riesgos detectados:

- Secuestro de sesión.
- Robo de credenciales.
- Phishing.
- Accesos no autorizados.
- Fuga de información.
- Uso indebido de cuentas personales.

Impacto potencial:

- Exposición de datos personales.
- Acceso indebido a documentos institucionales.
- Afectación a la continuidad operativa.
- Riesgos legales y administrativos.





SECCIÓN I: ALCANCE DEL SGSI

El Sistema de Gestión de Seguridad de la Información (SGSI) se implementará inicialmente dentro del **Departamento de Recursos Humanos del SEER.**

Relación con la problemática

La política “*Uso de Servicios en la Nube*” fue priorizada debido al uso constante de:

- Correo institucional.
- OneDrive.
- Microsoft Teams.
- Compartición de archivos en la nube.

Esto incrementa riesgos relacionados con:

- Robo de credenciales.
- Accesos no autorizados.
- Phishing.
- Secuestro de sesión.

Objetivo del alcance

Proteger la información institucional mediante controles de seguridad aplicados específicamente a los servicios en la nube utilizados por el personal administrativo.



SECCIÓN II: REFERENCIAS NORMATIVAS

Normas utilizadas

- ISO 27000: conceptos y vocabulario
- ISO 27001: requisitos del SGSI
- ISO 27002: controles de seguridad
- ISO 27005: gestión de riesgos
- ISO 27018: protección de datos en la nube



SECCIÓN II: REFERENCIAS NORMATIVAS

Aplicación en la problemática

ISO 27001 permite controlar riesgos asociados al uso de Office 365 mediante:

- Autenticación multifactor.
- Control de accesos.
- Gestión de incidentes.
- Monitoreo de actividad.
- Concientización del personal.

SECCIÓN III: TÉRMINOS Y DEFINICIONES

Conceptos importantes del SGSI

- **Activo:** Elemento valioso para la organización.
 - Ejemplos: Cuentas de Office 365. Correos institucionales. Expedientes digitales.
- **Amenaza:** Situación que puede afectar la seguridad.
 - Ejemplos: Phishing. Robo de credenciales. Malware.
- **Vulnerabilidad:** Debilidad que puede ser explotada.
 - Ejemplos: Contraseñas débiles. Falta de capacitación. Uso incorrecto de servicios en la nube.
- **Riesgo:** Probabilidad de que una amenaza aproveche una vulnerabilidad.
 - Ejemplo: Un atacante roba credenciales de Office 365 mediante phishing.



SECCIÓN IV: CONTEXTO DE LA ORGANIZACIÓN

Contexto interno

El Departamento de Recursos Humanos administra información sensible relacionada con:

- Personal docente.
- Información administrativa.
- Expedientes.
- Trámites laborales.

La dependencia utiliza servicios en la nube como parte de sus operaciones diarias.

Necesidad del SGSI

Implementar controles de seguridad para:

- Reducir riesgos.
- Proteger información.
- Mejorar monitoreo.
- Fortalecer la cultura de seguridad.

Necesidad del SGSI

Implementar controles de seguridad para:

- Reducir riesgos.
- Proteger información.
- Mejorar monitoreo.
- Fortalecer la cultura de seguridad.

SECCIÓN IV: CONTEXTO DE LA ORGANIZACIÓN

Identificación de activos internos y externos relevantes para el SGSI del SEER.

Activos internos:

- Infraestructura tecnológica (computadoras, servidores, red)
- Información crítica (datos de alumnos y docentes)
- Software y licencias (Office 365, Windows, sistemas institucionales)
- Recursos humanos y conocimiento del personal
- Documentación, procesos y políticas internas

Activos externos:

- Normativas y regulaciones federales y estatales
- Proveedores de servicios (internet, software, infraestructura)
- Plataformas externas (SEP, SIGED, autenticación)
- Convenios, certificaciones y servicios de terceros
- Infraestructura y recursos compartidos con otras entidades

SECCIÓN V: LIDERAZGO

Participación de la dirección

La implementación del SGSI requiere apoyo de:

- Dirección administrativa.
- Departamento de Informática.
- Responsables de Recursos Humanos.

Política aplicada: Uso de Servicios en la Nube

Controles establecidos:

- Uso exclusivo de cuentas institucionales.
- Activación obligatoria de 2FA.
- Restricción de cuentas personales.
- Monitoreo de accesos.

Objetivo del liderazgo

Garantizar que todo el personal:

- Conozca las políticas.
- Cumpla procedimientos.
- Proteja la información institucional.
- Reporte incidentes de seguridad.



SECCIÓN VI: PLANIFICACIÓN Y GESTIÓN DE RIESGOS

Riesgo identificado: Uso inseguro de servicios en la nube

Amenazas asociadas:

- Robo de credenciales.
- Accesos externos.
- Secuestro de sesión.
- Phishing.

Evaluación del riesgo: Se determinó que el riesgo debía **Mitigarse** (Debido al impacto potencial sobre la *Confidencialidad*, la *Integridad* y la *Disponibilidad*)

Medidas implementadas

- Autenticación de Dos Factores (2FA).
- Uso obligatorio de Office 365 institucional.
- Monitoreo de accesos.
- Capacitación en phishing.
- Restricción de accesos sospechosos.

Resultados esperados

- Reducción de accesos no autorizados.
- Mayor protección de datos.
- Mejor control de identidades.
- Disminución de incidentes.

PLANIFICACIÓN DE RIESGOS - Política

Externa 1: Uso de Servicios en la Nube

(Office 365)



**P-E1 -> Secuestro
de sesión en Office
365**

Ubicación de
acuerdo al nivel de
riesgo

				P-E1 (15 - Muy Alto)

**GRACIAS POR
SU ATENCIÓN**